DORA AI Ajan Paketi — Uygulama Raporu

Sürüm: 0.6.0 · **Tarih:** 8 Kasım 2026 · **Sahip:** ustauretim **Depo:** https://github.com/atlantis77ut/dora-ai-package · **Canlı dashboard:** https://atlantis77ut.github.io/dora-ai-package/

---

1. Yönetici özeti

DORA AI Ajan Paketi, finansal kuruluşların DORA (Digital Operational Resilience Act) uyumunu **yapay zekâ ajanlarıyla yürütmesi** için tasarlanmış, açık kaynak bir referans çerçevesidir. Bir yazılım ürününden çok **çalıştırılabilir bir uyum modeli** sunar: süreçler, kontroller, roller ve kanıt şartnameleri makine okunur dosyalar hâlinde tanımlanır; bir komut satırı aracı (CLI) bu modeli altı fazda kuruma uygular ve her fazın sonunda **geçiş kapısı** ile kanıt ister.

Paketin bugünkü ölçeği:

Bileşen	**Sayı**
DORA yükümlülük maddesi (eşlenen)	28 — **%100 kapsanıyor** (28 covered, 0 partial, 0 gap)
Süreç	23 (5 sütun)
Kontrol	35 (kanıt şartnameli)
Ajan rolü	11 (üç savunma hattı)
Sözlük terimi	60
Sentetik kabul senaryosu	4 (27 assertion)
CORF fazı	6 (C1–C6)
JSON Şema	5

Ne değildir: bir LLM orkestrasyon motoru değil, bir ajan çalıştırıcısı değil, hukuki görüş değil. Paket; süreçleri, yetkileri ve kanıt kurallarını tanımlar; ajanların gerçek çalıştırıcısı bilinçli olarak kapsam dışıdır (bkz. §13).

---

2. Hangi problemi çözüyor

DORA, 17 Ocak 2025'ten itibaren AB'deki finansal kuruluşlar için bağlayıcı. Beş sütunu var: ICT risk yönetimi, olay yönetimi, dayanıklılık testleri, üçüncü taraf riski ve bilgi paylaşımı. Türkiye'de BDDK/TCMB mevzuatı ile birlikte okunması gerekiyor.

Bankaların pratikte yaşadığı üç sorun:

1. **Süreçler belgede kalıyor.** Risk çerçevesi Word'de, olay akışı Excel'de, kanıt e-postada. Denetçi "göster" dediğinde parçalar birleşmiyor.
2. **Süreler tutmuyor.** DORA ilk bildirimi 4 saatte istiyor; hangi olayın "büyük" sayıldığı, kimin onayladığı, sayacın ne zaman başladığı çoğu kurumda tanımlı değil.
3. **Ajan kullanımı denetlenemiyor.** Kurumlar LLM tabanlı araçları deniyor ama hangi ajanın hangi kararı verebileceği, hangi noktada insan onayı gerektiği yazılı değil.

Paket bu üç soruna aynı yerden cevap verir: **her yükümlülük bir sürece, her süreç bir kontrole, her kontrol bir kanıt şartnamesine bağlanır.**

3. Mimari — üç katman

Katman	İçerik	Kaynak
3. Çalıştırma	Ajanlar (11 rol) + insan onay noktaları; GOLDENHORN/CORF platformuna API ile bağlanır (tasarım)	`data/roles/`, `onboarding/corf-lifecycle.yaml`
2. Süreç	23 süreç, 35 kontrol, 5 sütun, CORF 6 fazı; her süreç: tetikleyici → girdi → SLA → kural → kanıt	`data/processes/`, `data/controls/`
1. Veri	60 terim, 11 rol, 28 DORA maddesi; YAML kaynak, JSON Schema ile doğrulama	`data/glossary/`, `schema/`

Katman kuralı: üst katman alt katmanı değiştiremez. Bir ajan, tanımlı olmayan bir kanıt üretemez; bir süreç, sözlükte olmayan bir terimi kullanamaz. Bu kural, denetimde "bu kayıt nereden geliyor" sorusunun cevabını tek yere indirir.

4. Veri modeli

Her şey YAML'da tutulur, JSON Schema ile doğrulanır. Beş şema vardır:

Şema	Ne tanımlar
`common`	Ortak tipler: Version, DoraReference, Tier, DefenceLine, SLA, Regulator, I18nText
`glossary`	Terim nesnesi, kategori, DORA/RTS referansı
`roles`	Rol, beceri, KPI, insan gözetimi, tier aktivasyonu
`processes`	Süreç, girdi/çıktı, SLA, karar kuralı, bağımlılık
`controls`	Kontrol tipi, kanıt şartnamesi, değiştirilemezlik, test prosedürü

4.1 Süreçler (23)

Sütun	Süreç	Örnek
1 — Risk	PRC-RSK-01…05	ICT risk çerçevesi, envanter, BCP/DRP, siber kontroller
2 — Olay	PRC-INC-01…07	tespit, ilk bildirim (4s), ara rapor (72s), nihai rapor (1 ay), gönüllü bildirim, kriz iletişimi, ödeme olayı
3 — Test	PRC-TST-01…03	test programı, test yürütme, TLPT
4 — Üçüncü taraf	PRC-TPP-01…06	durum tespiti, kritiklik, sözleşme, RoI, CTPP, çıkış

Sütun	Süreç	Örnek
5 — Bilgi paylaşımı	PRC-INF-01…02	istihbarat toplama, paylaşım

Her süreç şu alanları taşır: tetikleyici, ön koşullar, girdiler (format + kaynak rol), çıktılar (format + saklama süresi), sorumlu ve onay rolleri, SLA'lar, karar kuralları (`INC-R1` gibi ID'li, DORA maddesine bağlı), bağımlılıklar, kanıt şartları ve tier varyantları.

4.2 Kontroller (35)

Aile	Adet	Örnek
CTL-RSK	11	değişiklik risk kapısı, erişim gözden geçirme, şifreleme, segmentasyon, yedekleme doğrulaması
CTL-INC	10	SIEM korelasyonu, dört-göz sınıflandırma, 4 saat sayacı, 72 saat takibi, kriz iletişimi, ödeme çift kanal
CTL-TST	4	test kapsamı, testçi bağımsızlığı, bulgu kapatma, TLPT döngüsü
CTL-TPP	7	durum tespiti tamlığı, yoğunlaşma eşiği, Madde 30 maddeleri, RoI bütünlüğü, çıkış tatbikatı
CTL-INF	3	gizlilik taraması, anonimleştirme doğrulaması, anlaşma geçerliliği

Her kontrolün bir **kanıt şartnamesi** vardır: hangi formatta (json/pdf/log/hash_chain/xbrl), hangi değiştirilemezlikte (append_only/hash_chain/worm_storage) ve hangi zorunlu alanlarla saklanacağı. Ayrıca denetçinin soracağı somut soruyu içeren bir `test_procedure` alanı bulunur.

4.3 DORA eşlemesi (28 madde)

`data/mapping/dora-articles.yaml` her yükümlülük maddesini süreç, kontrol ve sahip rolle eşler. Bugünkü durum: **28 covered, 0 partial, 0 gap.** Eşleme iki yönlü doğrulanır — tanımsız bir süreç/kontrol referansı olamaz, katalogdaki her süreç ve kontrol en az bir maddede görünmek zorundadır.

---

5. Nasıl çalışır — CORF altı fazı

Kurulum altı fazda yapılır. Her fazın adımları, çıkış kriterleri ve süresi `corf-lifecycle.yaml` içinde tanımlıdır; CLI bu dosyayı okur ve kapıları çalıştırır.

Faz	Ad	Adım	Kriter	Süre	Ajan modu
C1	Identify — önemli iş hizmetleri	4	4	10 gün	observe
C2	Set Tolerances — etki toleransları	4	4	8 gün	observe

Faz	Ad	Adım	Kriter	Süre	Ajan modu
C3	Map Resources — envanter + ajan aktivasyonu	7	7	20 gün	observe
C4	Scenario Tests — senaryo testleri	5	4	12 gün	recommend
C5	Self-Assessment — öz değerlendirme	4	4	10 gün	recommend
C6	Implement MOS — işletim sistemine geçiş	6	4	45 gün	act_with_approval

Kapı mantığı: her kriter çalıştırılabilir bir kontroldür (ör. "her hizmetin sahibi var mı?", "4 saat SLA tanımlı mı?", "kapsama matrisi dolu mu?"). Kapı geçilmezse CLI çıkış kodu **2** döner ve sonraki faz başlatılamaz. Bu, "yaptık sayalım" kültürünü teknik olarak engeller.

Otonomi merdiveni: ajanların yetkisi fazlarla birlikte artar:

```
observe → recommend → act_with_approval → act_autonomous
(C1-C2)     (C3-C4)       (C5-C6)              (yalnız C6, düşük etkili işler)
```

Ajanın *yeteneği* değişmez; **yetkisi** değişir. Her rolde `human_oversight.required_for` alanı hangi kararlarda insan onayı gerektiğini yazılı hâle getirir.

---

6. Komut satırı aracı

CLI bağımlılıksızdır: `npm install` gerekmez, Node 18+ yeterlidir.

```
node bin/dora-onboard.mjs phases                        # faz tanımını doğrula
node bin/dora-onboard.mjs init --tier tier2 --regulator BDDK
node bin/dora-onboard.mjs phase C1 --session ob-2026-xxxxx --demo
node bin/dora-onboard.mjs gate  C1 --session ob-2026-xxxxx    # geçmezse çıkış 2
node bin/dora-onboard.mjs status --session ob-2026-xxxxx
node bin/dora-onboard.mjs rollback --session ob-2026-xxxxx --to-phase C1
```

Komut	İş
`init`	Oturum açar; tier, regülatör, yargı alanı ve lisans kaydedilir
`phase`	Fazı çalıştırır, artefaktları üretir (`--demo` örnek veri yazar)
`gate`	Fazın çıkış kriterlerini değerlendirir
`status`	Faz/faz durum, kapı sonucu ve artefakt sayısı
`phases`	Lifecycle dosyasını doğrular ve özetler
`rollback`	Belirtilen faza döner, sonraki fazların çıktısını temizler
`export`	Kanıt paketi üretir: ZIP + manifest + hash zinciri + Ed25519 imza
`verify`	Paketin dosya özetlerini, zincirini ve imzasını doğrular

Komut	İş
`notify`	ITS 2024/2956 bildirim formunu doldurur (json/md/html), eksik alanı işaretler

Oturum verisi `.dora-onboarding/<oturum-id>/` altında JSON olarak tutulur: kurum profili, yargı alanı, iş hizmetleri kataloğu, etki toleransları, risk iştahı, envanter, ajan aktivasyonu, senaryo sonuçları, kapsama matrisi, boşluk analizi, otonomi atamaları, go-live kaydı.

Örnek: gerçek demo çıktısı

```
C1  Faz 1 — Önemli İş Hizmetlerinin Belirlenmesi (Identify)
   ✔ tier2 · Demo Bankası A.Ş. · bitiş 2027-11-08  [LIC]
   ✔ tier=tier2  [C1-1]
   ✔ TR/BDDK  [C1-2]
   ✔ 2 hizmet  [C1-3]
   ✔ 2 hizmet tam  [C1-4]
   -> KAPI GECILDI
...
SONUC: 6/6 faz gecildi
```

Demo, kendi geçici oturumunu açar, altı fazı çalıştırır ve sonunda siler — gerçek kuruluma dokunmaz.

---

7. Dashboard

Dashboard, depodaki YAML'lardan **üretilir**; elle düzenlenmez. Üç sayfa vardır ve tek dosya HTML olarak (harici CDN/font olmadan) `file://` ile açılır — kapalı ağda çalışır.

Sayfa	İçerik
`index.html`	KPI kartları (23 süreç · 35 kontrol · 11 ajan · 60 terim · 4 senaryo · %100), kapsama çubuğu, CORF faz tablosu, açık noktalar, senaryo listesi
`processes.html`	23 sürecin tablosu + her süreç için tetikleyici, girdi/çıktı, SLA, karar kuralları, kontroller, bağımlılıklar
`controls.html`	35 kontrolün tablosu + kanıt alanları, değiştirilemezlik, DORA maddesi, test prosedürü

Üretici `docs/tools/build-dashboard.mjs`; sarkan bir referans bulursa çıkış kodu 1 döner, yani dashboard aynı zamanda bir **bütünlük testidir**. PNG kopyası Pillow ile üretilir (tarayıcısız).

---

8. Doğrulama ve kalite

Dört kontrol her push'ta GitHub Actions'ta çalışır:

Kontrol	Ne yapar
`render-mapping.mjs --check`	28 maddeyi doğrular; tanımsız referans, tekrarlanan ID, gerekçesiz gap ve **eşlemede görünmeyen süreç/kontrol** arar
`build-dashboard.mjs`	YAML'lardan siteyi üretir; sarkan referansta kırılır

Kontrol	Ne yapar
`dora-onboard.mjs phases`	Lifecycle dosyasının yapısal geçerliliğini denetler
`demo.mjs`	Altı fazı örnek veriyle uçtan uca çalıştırır
`demo-export.mjs`	Kanıt paketi + doğrulama + kurcalama testi + üç bildirim formu

Ek olarak `build-coverage-summary.mjs` kapsam tablosunu (`docs/KAPSAM-OZETI.md`) üretir.

---

9. Lisanslama modeli

İki lisans vardır:

Kullanım	Lisans
İnceleme, değerlendirme, iç kullanım, açık kaynak projeler	**AGPL-3.0**
Kapalı kaynak ürüne gömme, ticari SaaS, yeniden satış, beyaz etiket	**Ticari lisans** (ücretli)

Bir bankanın paketi kendi içinde kullanması AGPL kapsamında kaynak açma yükümlülüğü doğurmaz; yükümlülük paketi üçüncü taraflara ürün/hizmet olarak sunmakla başlar.

Lisans anahtarı: Ed25519 imzası, çevrimdışı doğrulama. Anahtarsız 30 gün deneme modu çalışır (C1–C5); üretime geçiş (C6) ticari lisans ister. İmza, süre ve tier her `init`/`phase`/`gate` çağrısında denetlenir; hatalı lisansta çıkış kodu 3'tür. `dev-private.pem` yalnız geliştirme içindir, `.gitignore`'dadır ve dağıtılmaz.

---

10. Uçtan uca örnek: büyük bir olay

```
T+0      SIEM alarmı                          → PRC-INC-01 (tespit)
T+30dk   sınıflandırma + dört-göz onayı        → PRC-INC-01, CTL-INC-002
T+4sa    ilk bildirim (DORA kanalı)           → PRC-INC-02, CTL-INC-003/004
T+4sa    ilk kamu açıklaması                  → PRC-INC-06, CTL-INC-009
T+72sa   ara rapor                            → PRC-INC-03, CTL-INC-005
T+1ay    nihai rapor + RCA                    → PRC-INC-04, CTL-INC-006/007
+
ödeme zinciri etkilendiyse çift kanal         → PRC-INC-07, CTL-INC-010
```

Her adımın bir çıktısı ve o çıktının kanıt şartnamesi vardır: `initial-notification.xml`, `notification-receipt.json`, `holding-statement.pdf`, `final-report.xml`, `rca-report.pdf`. Süreler DORA tabanına sabitlenmiştir; yerel mevzuat daha uzun süre öngörse bile gevşetme yapılmaz (DR-001 kararı).

---

11. Kapsam tablosu

Bölüm	Madde	Durum
II — ICT Risk Yönetimi	12	12 covered

Bölüm	Madde	Durum
III — Olay Yönetimi	5	5 covered
IV — Test	4	4 covered
V — Üçüncü taraf riski	6	6 covered
VII — Bilgi paylaşımı	1	1 covered
Toplam	**28**	**28 covered · %100**

Eşleme yalnızca yükümlülük doğuran maddeleri kapsar; tanım maddeleri (Madde 3 vb.) ve gözetim/yaptırım hükümleri kapsam dışıdır. Bu sınır belgede açıkça yazılıdır — "%100" iddiası "DORA'nın 28 yükümlülük maddesi" ile sınırlıdır.

---

12. Sınırlar — paketin ne olmadığı

Dürüst bir rapor, sınırları da yazmalı:

4. **Ajan çalıştırıcısı yok.** Paket rolleri, süreçleri ve kapıları tanımlar; LLM orkestrasyonu (araç çağırma, hafıza, kuyruk) kapsam dışıdır. `autonomy_level` alanları bu katmanın sözleşmesidir, uygulaması değil.
5. **GOLDENHORN/CORF API adaptörü tasarımdır**, kodlanmamıştır.
6. **Otomatik kod testi yok.** Doğrulama, veri ve akış bütünlüğü düzeyindedir.
7. **Hukuki görüş değildir.** BDDK/SPK/KVKK eşlemesi bilgi amaçlıdır; avukat onayı gerekir.
8. **ITS XBRL taksonomi bağlaması açık.** Alan sözlüğü var, resmi taksonomi kodlarının bağlanması uygulama adımıdır.
9. **Kanıt paketi şifrelenmez ve PKI yok.** Bütünlük (hash zinciri + imza) kanıtlanır; gizlilik ve anahtar sahipliği kanıtlanmaz. Bildirim formu resmi XBRL taksonomisine bağlanmaz.
10. **Yönetim kurulu MI paketi tanımlı değil.**

---

13. Yol haritası

Sürüm	İş
0.5 (ertelendi)	Yönetim kurulu MI paketi + düzenleyici takvim + RoI yıllık sunum formatı
~~0.6~~	**Tamamlandı** — kanıt paketi (export/verify) + bildirim formu (notify)
0.7	Splunk / ServiceNow / Archer konnektörleri, GOLDENHORN adaptörü
1.0	Deterministik kural motoru (CEL/Rego), üretim sertleştirmesi

---

14. Kurulum

```
git clone https://github.com/atlantis77ut/dora-ai-package.git
cd dora-ai-package/onboarding/cli
node bin/dora-onboard.mjs phases
node bin/dora-onboard.mjs init --tier tier2 --regulator BDDK
```

Windows'ta kısayollar: `scripts\dashboard.cmd`, `scripts\demo.cmd`, `scripts\validate.cmd`. Doğrulama: `node docs/tools/render-mapping.mjs --check` ve `node onboarding/cli/tools/demo.mjs`.

Bu rapor 0.4.1 sürümüne göredir. Sayılar depodaki YAML dosyalarından üretilir; çelişki hâlinde kaynak dosyalar esastır.